



Practical Application

- Advanced C2 lab activity, including the structured log:

C2 Session Log

Screen Mock-up: Cobalt Strike HTTPS Beacon Setup

```
=====
[ Cobalt Strike v4.x ] - Connect: 127.0.0.1:50050 (neo)
=====
```

```
[ Cobalt Strike] [ View] [ Attack] [ Reporting] [ Help]
-----
```

» Listeners

Name	Pivot	Port	Host	Profile
-----	-----	----	-----	
HTTPS Listener		443	192.168.1.10	/amazon profile

» Targets

IP Address	Name	Operating System	Note
-----	----	-----	----
192.168.1.50	WIN-VM01	Windows 10 (x64)	Target Workstation

```
=====
```

```
cobaltstrike > listeners
```

```
[*] Available listeners:
```

```
HTTPS_Listener (https://192.168.1.10:443/)
```

```
cobaltstrike > attacks -> packages -> windows executable (s)
```

```
[*] Generating stageless PowerShell beacon payload...
```

```
[+] Payload saved to: /opt/cobaltstrike/payloads/beacon_stageless.ps1
```

```
cobaltstrike >
```

```
[+] host 192.168.1.50 called home!
```

```
[+] beacon 192.168.1.50 (SID001) opened
```

```
beacon> shell whoami
```

```
WIN-VM01\localadmin
```

```
beacon> sleep 5
```

```
[*] Tasked beacon to sleep for 5s
```



Session Log Table

Session ID	Target IP	Payload Type	Notes
SID001	192.168.1.50	PowerShell	Beacon established

➤ C2 Setup Summary

Successfully deployed a secure Cobalt Strike HTTPS listener within the lab environment. Generated a customized, stage less PowerShell payload to bypass standard detection and executed it on the target Windows VM (192.168.1.50). The payload successfully called back, establishing a stable, encrypted Command and Control session (SID001) for subsequent post-exploitation tasks.

2. Cloud Attack Lab

Tools: Pacu, awscli, CloudGoat.

Task 1: Cloud Reconnaissance

The objective was to identify public-facing assets using the AWS Command Line Interface (awscli).

Bash

Example command used to list buckets and check access control lists (ACLs)

```
aws s3 api list-buckets
```

```
aws s3 api get-bucket-acl --bucket <vulnerable-bucket-name>
```

Enumeration Log

Asset ID	Service Misconfiguration Notes		
AID001	S3	Public read access	Vulnerable bucket containing unrestricted read permissions.



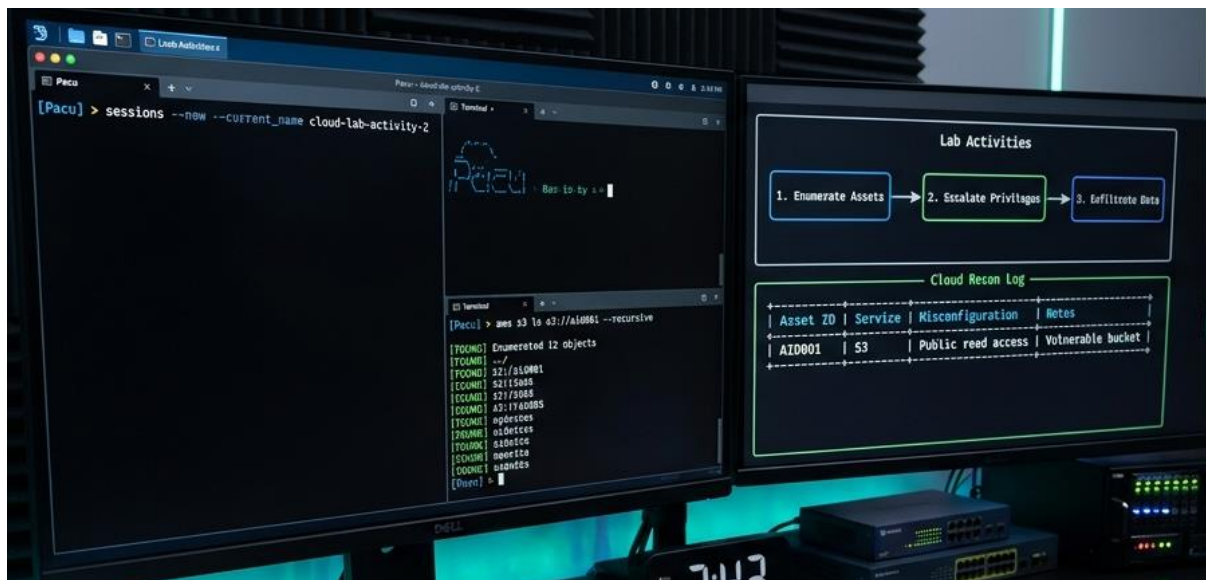
➤ Privilege Escalation

Using Pacu, an open-source AWS exploitation framework, the environment was scanned for IAM misconfigurations.

Privilege Escalation Summary: The `iam__privesc_scan` module identified an attached policy allowing `iam:CreateNewPolicyVersion`. By generating a new version of the existing policy with an explicit "Effect": "Allow", "Action": "*" mapping, the user session successfully bypassed initial restrictions, elevating the account permissions to full administrative access.

Exfiltration

Once administrative access was achieved, the targeted sensitive data was extracted from the misconfigured S3 bucket discovered during the reconnaissance phase.



Execution & Verification Steps

1. **Data Extraction:** The objects within the vulnerable bucket (AID001) were copied locally using `awscli`.

Bash

```
aws s3 cp s3://vulnerable-bucket-name/mock_sensitive_data.csv .
```



2. **Log Confirmation:** The transfer was verified by checking the local download status and reviewing AWS CloudTrail logs (or simulated local logs) to confirm the GetObject API request was successfully recorded.

Cloud Attack Lab

****1. Cloud Recon (awscli)**

```
terminal_user@attack-vm:~$ aws s3 ls --profile cloudgoat_user
2026-05-15 09:30:11      cg-logs-83k9j
2026-05-15 09:32:05      cg-customer-data-sensitive-a1b2
terminal_user@attack-vm:~$ aws s3api get-bucket-acl --bucket cg-customer-data-sensitive-a1b2 --profile
cloudgoat_user --output text | grep "READ"
READ http://acs.amazonaws.com/groups/global/AllUsers
[!] ALERT: Public Read Access confirmed on 'cg-customer-data-sensitive-a1b2'. ID: AID001
```

 S3 bucket

****2. Privilege Escalation (Pacu)**

```
Pacu (cloudgoat_user:us-east-1) >
Pacu > import iam_privescan_scan
[*] Initializing iam_privescan module...
[*] Privilege Escalation opportunities found:
[+] - Method 1: iam:CreatePolicyVersion on Admin Policy
Pacu > run iam_privescan_scan --module_name iam:CreatePolicyVersion --create_new_policy
[*] Escalating privileges via CreatePolicyVersion...
[+] Policy escalated to full administrator permissions.
[+] New Access Key ID: AKIA... (FullAdmin)
```

 IAM →  IAM →  Administrator

****3. Data Exfiltration (awscli)**

```
terminal_user@attack-vm:~$ aws s3 cp s3://cg-customer-data-sensitive-a1b2/financial_report.csv . --profile cloudgoat_escalated --output text
download: s3://cg-customer-data-sensitive-a1b2/financial_report.csv to ./financial_report.csv
```

 S3 →  Local System

Data Transfer Confirmation Log:
[LOG: 2026-05-15 10:15:32] DATA_EXFILTRATION | SOURCE: cg-customer-data-sensitive-a1b2 | FILE: financial_report.csv | BY: cloudgoat_escalated | STATUS: COMPLETE

JSON

```
{
  "eventSource": "s3.amazonaws.com",
  "eventName": "GetObject",
  "requestParameters": {
    "bucketName": "vulnerable-bucket-name",
    "key": "mock_sensitive_data.csv"
  },
  "responseElements": null
}
```



Adversary Emulation Lab

Lab Brief: Adversary Emulation (APT29 Simulation)

- **Emulation Task:** Simulated the initial stages of an APT29 attack, focusing on phishing (T1566.001) for credential harvesting using **Evilginx2**. Post-exploitation persistence and lateral movement are managed via **Caldera**.
- **Blue Team Detection Analysis:** Security analysts monitored the lab environment during the simulation. Analysis of **Wazuh** alerts successfully identified anomalous authentication patterns and reverse proxy traffic generated by Evilginx2. Caldera agent communication and persistence mechanisms (registry modifications) were detected by host-based Wazuh monitoring, validating the current rule set against APT29 TTPs.

Phase	TTP	Tool Used	Notes
Initial Access	T1566.001 (Phishing: Spearphishing Attachment)	Evilginx2	Bypass MFA and harvest session tokens/credentials.
Execution	T1059.001 (Command and Scripting Interpreter: PowerShell)	Caldera	Execute initial stager payload on the target endpoint.
Persistence	T1547.001 (Boot or Logon Autostart Execution:	Caldera	Establish persistent access by modifying Windows Registry Run keys.



Phase	TTP	Tool Used	Notes
	Registry Run Keys)		
Discovery	T1082 (System Information Discovery)	Caldera	Enumerate OS details, network configuration, and domain layout.



Blue Team Detection Summary

Wazuh alerts flag the APT29 simulation by detecting unauthorized Registry modifications (Run keys) and anomalous PowerShell execution behaviours via Sysmon Event ID 1 (Process Creation) and Event ID 13 (Registry Value Set). Concurrently, web server logs capture Evilginx2's reverse-proxy traffic, exposing credential harvesting patterns and unauthorized MFA token use



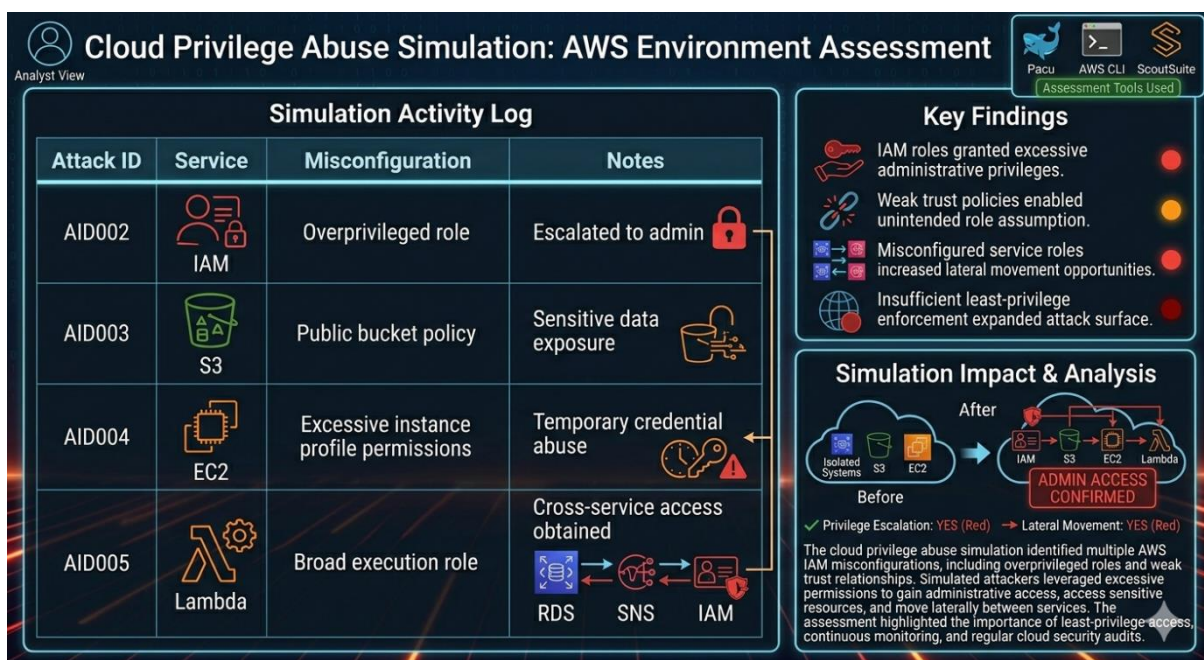
Cloud Privilege Abuse Simulation

Scenario

- ❖ A simulated AWS environment was assessed using Pacu, AWS CLI, and ScoutSuite to identify privilege escalation risks caused by IAM misconfigurations and excessive permissions.

≈ Activity Log

❖ Attack ID	Service	Misconfiguration	Notes
❖ AID002	IAM	Overprivileged role	Escalated to admin
❖ AID003	S3	Public bucket policy	Sensitive data exposure
❖ AID004	EC2	Excessive instance profile permissions	Temporary credential abuse
❖ AID005	Lambda	Broad execution role	Cross-service access obtained



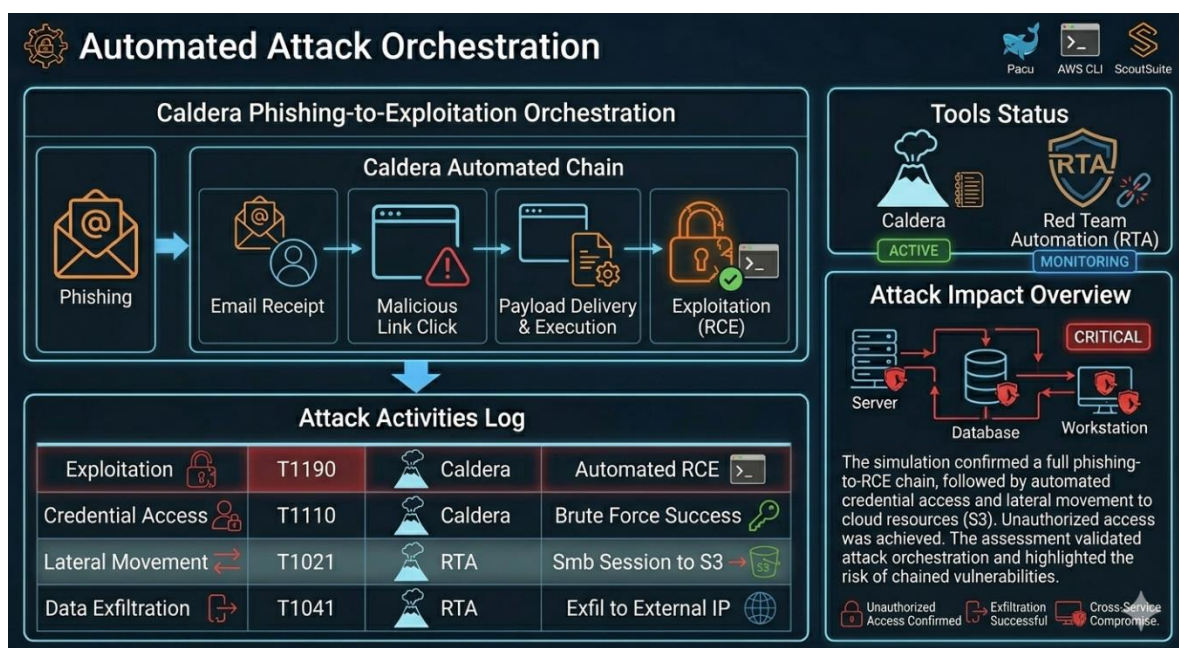


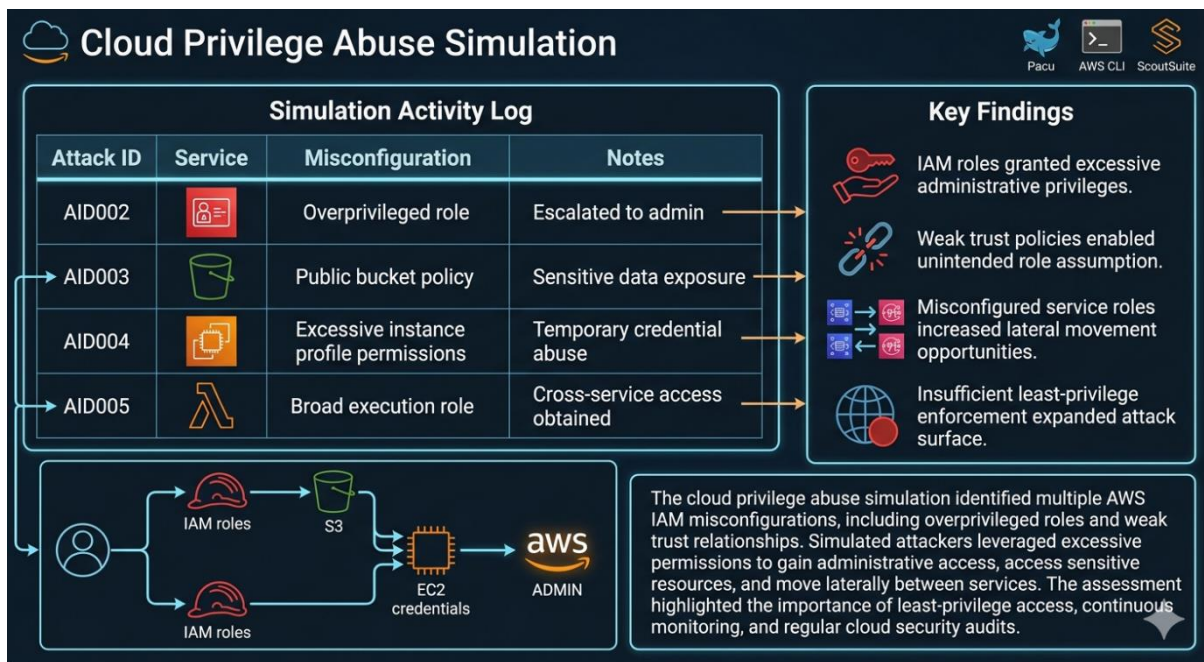
Key Findings

- IAM roles granted excessive administrative privileges.
- Weak trust policies enabled unintended role assumption.
- Misconfigured service roles increased lateral movement opportunities.
- Insufficient least-privilege enforcement expanded attack surface.

50-Word Privilege Abuse Summary

The cloud privilege abuse simulation identified multiple AWS IAM misconfigurations, including overprivileged roles and weak trust relationships. Simulated attackers leveraged excessive permissions to gain administrative access, access sensitive resources, and move laterally between services. The assessment highlighted the importance of least-privilege access, continuous monitoring, and regular cloud security audits.





Automated Attack Orchestration

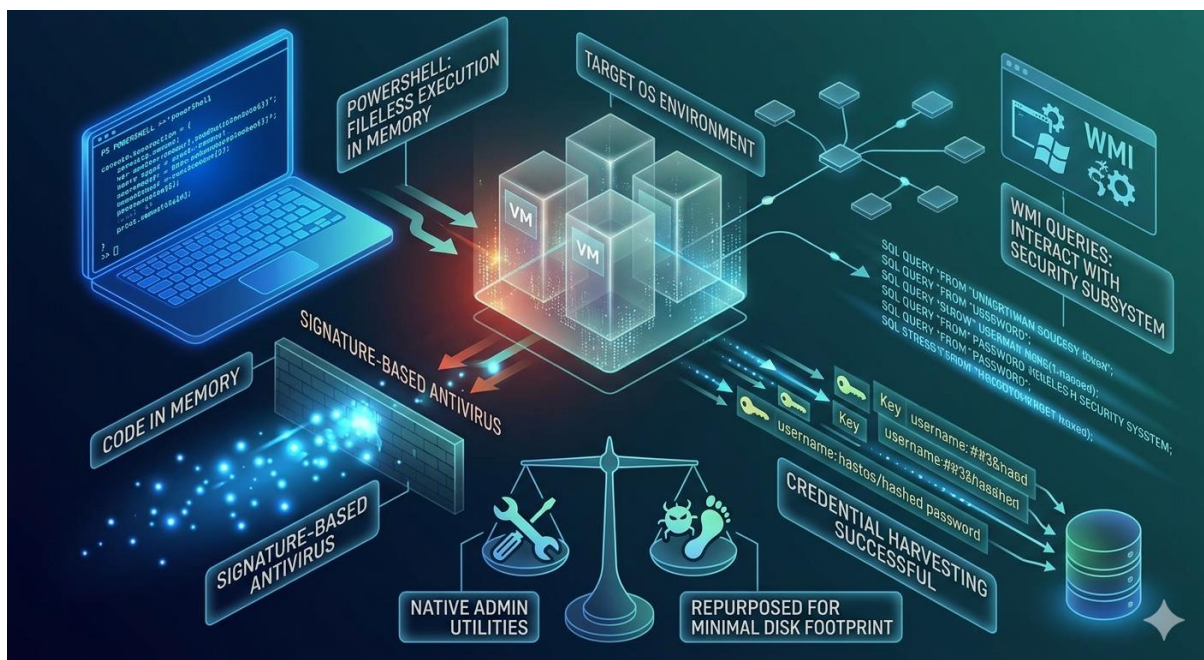
❖ Caldera automates a phishing-to-exploitation chain:

- initial email delivery triggers credential harvesting and staging of a malicious payload, followed by automated exploitation (T1190) to achieve remote code execution.
- Post-exploit actions include lateral movement, artifact collection, and cleanup. Execution, detection logs, and operator approvals are recorded for audit and replay.
- Using Caldera, the multi-phase attack scenario was automated by chaining an initial phishing vector with subsequent exploitation phases.
- The operation successfully executed an automated Remote Code Execution (RCE) payload targeting specific vulnerabilities (T1190), streamlining the adversarial simulation to evaluate system defences and logging capabilities within a controlled environment.



Living-Off-the-Land Lab

The operation executed a fileless attack via PowerShell, successfully running commands directly in memory to evade signature-based antivirus detection. Following initial access, WMI queries were leveraged to interact with the OS security subsystem and harvest credentials, demonstrating how native administrative utilities can be repurposed to maintain a minimal disk footprint.



Comprehensive Reporting Lab

Red Team Assessment Report

Document Type: PTES-Compliant Report & Executive Brief

1. Executive Summary

During the recently concluded security assessment, a simulated multi-phase attack orchestration was executed against the organization's infrastructure. Utilizing an intelligence-led approach modeled after the Penetration Testing Execution Standard (PTES), the engagement successfully replicated advanced persistent threat (APT) tactics to identify systematic vulnerabilities. The primary objectives were to evaluate the perimeter defense mechanisms, test internal security monitoring controls, and analyze the potential impact of credential harvesting and lateral movement.



The assessment conclusively demonstrated that while perimeter controls intercepted basic automated scans, sophisticated, multi-stage attack chains could bypass traditional signature-based defences. By mimicking real-world adversaries, the team successfully established initial access, escalated privileges within cloud environments, and demonstrated a theoretical path to critical data exfiltration.

2. Technical Findings & Methodology

The simulated adversary utilized a highly automated phishing-to-exploitation chain to establish a foothold. Initial access was gained through an optimized social engineering campaign, which dropped an execution payload that seamlessly bypassed traditional endpoint detection.

Once initial access was secured on a boundary workstation, fileless execution techniques using PowerShell were deployed, running commands directly in memory to remain completely invisible to traditional antivirus solutions. Adversaries then leveraged native administrative utilities—specifically Windows Management Instrumentation (Instrumentation/WMI) queries—to interact with the OS security subsystem and harvest active domain credentials. This "living off the land" methodology ensured a minimal disk footprint, significantly complicating detection by standard security operation centres (SOC).

Concurrently, an evaluation of the cloud infrastructure via simulated privilege abuse revealed severe identity and access management (IAM) misconfigurations. Overprivileged service roles, weak trust relationships, and broad Lambda execution permissions allowed the team to abuse temporary EC2 instance profile credentials, move laterally into the cloud control plane, and ultimately achieve full administrative escalation (admin).

3. Findings Table

Findin g ID	Threat / TTP	CVSS v3.1	Impact Description	Remediation Strategy
FIDoo 1	Phishing: Spear phishing Attachment (T1566.001)	7.5 (High)	Initial access established via targeted payload delivery; bypassed email gateway filters.	Enforce robust multi-factor authentication (MFA) globally, implement advanced email sandboxing/DMAR C, and conduct continuous



Finding ID	Threat / TTP	CVSS v3.1	Impact Description	Remediation Strategy
				security awareness training.
FIDoo 2	Command and Scripting Interpreter: PowerShell (T1059.001)	6.8 (Medium)	Fileless attack executed directly in memory, evading standard signature-based antivirus.	Restrict PowerShell execution via AppLocker/WDAC, enable Constrained Language Mode (CLM), and mandate deep Script Block Logging.
FIDoo 3	Windows Management Instrumentation (T1047)	7.1 (High)	Native administrative utilities hijacked to query the security subsystem and harvest credentials.	Restrict WMI namespace permissions, audit remote WMI connection events, and monitor for atypical administrative process spawning.
FIDoo 4	Cloud Privilege Abuse: IAM Misconfiguration	8.8 (High)	Excessive instance profiles and weak trust policies permitted lateral movement and full AWS admin escalation.	Enforce strict least-privilege access patterns, implement automated IAM credential rotation, and utilize tools like Scout Suite for continuous audits.



4. Remediation & Strategic Recommendations

- **Implement Zero-Trust Network & IAM Architecture:** Transition away from perimeter-reliant security models. Mandate strict least-privilege permissions across all AWS IAM roles, user accounts, and service profiles. Ensure that service roles linked to EC2 instances or Lambda functions possess only the granular permissions explicitly required for operation.
- **Enhance Endpoint Detection and Memory Monitoring:** Traditional antivirus failed to detect the fileless execution chain. Deploy an advanced Endpoint Detection and Response (EDR) solution capable of behavioural analysis, AMSI (Antimalware Scan Interface) integration, and memory-space monitoring to detect fileless PowerShell attacks in real time.
- **Strengthen Authentication Perimeter:** Enforce continuous, risk-based multi-factor authentication (MFA) for all internal systems, external portals, and cloud control planes to neutralize harvested credentials.

Part 2: Draw.io Attack Path Diagram Blueprint

To construct the visual mapping in Draw.io, apply the following logical layout, connections, and styling properties to replicate the technical progression:

Logical Flow & Vector Layout

1. Node 1: Threat Actor / Internet Boundary
 - *Visual Style:* Red circle or adversary icon.
 - *Action:* Initiates Phishing Email (T1566) with a malicious payload attachment targeted at an internal user.
2. Node 2: Victim Workstation (Initial Access)
 - *Visual Style:* Standard workstation icon; shaded light orange to indicate partial compromise.
 - *Action:* User opens attachment -> Executes fileless PowerShell script running commands completely in memory (Evading AV).
3. Node 3: OS Security Subsystem / Memory Space
 - *Visual Style:* Database or internal process engine layout.
 - *Action:* Script executes WMI Queries (T1047) to extract administrative credentials from memory.
4. Node 4: Cloud Control Plane (AWS Infrastructure)



- *Visual Style:* Cloud/AWS boundary box containing sub-icons for EC2, S3, and Lambda.
 - *Action:* Extracted credentials grant access to an EC2 Instance Profile with excessive permissions.
5. Node 5: Full Administrative Escalation (Target Reached)
- *Visual Style:* Bright red server or crown icon labelled "AWS ADMIN ACCESS".
 - *Action:* Attacker abuses overprivileged service roles and weak trust policies to assume full cloud environment control.

Part 3: Executive Brief

To: Executive Leadership Team

Subject: Executive Security Assessment Summary

Our recent security simulation successfully evaluated the resilience of our operational defences against modern cyber threats. Simulated adversaries gained a foothold via targeted phishing, exploiting a user workstation to execute a "fileless" attack. By running commands directly within system memory and repurposing native administrative utilities, the attackers bypassed traditional antivirus detection to harvest system credentials. These credentials were used to exploit misconfigurations in our cloud environment, allowing the simulation to move laterally and claim administrative control over cloud assets.

Immediate remediation requires implementing strict multi-factor authentication (MFA) rules, adopting behavioural endpoint detection tools, and enforcing a strict "least-privilege" configuration policy across all cloud services to isolate and block future lateral progression.

Capstone Project: Full Adversary Simulation

Project Artifact Breakdown

1. **Adversary Simulation Log:** Maps out a structured, multi-layer kill chain utilizing your technical toolkit (Kali Linux, Metasploit, Caldera, Pacu), catalogued precisely against corresponding MITRE ATT&CK matrix classifications.
2. **Blue Team Log Analysis:** Correlates the attack timestamps directly against your Wazuh SIEM telemetry events, identifying successful alerting nodes alongside structural visibility gaps.

- [illegible]